DISA STIG Compliance for Windows 10 & 11 in Microsoft Intune — Government (GCC High)

Implementation Solution Guide

Version 1.0.0 · 2026-07-01

Contents

Executive Summary — DISA STIG Compliance for Windows 10 & 11 in Microsoft Intune (Government / GCC High edition) 5

- The situation . . . 5
- The problem this solves . . . 5
- What we deliver . . . 5
- What we deliberately do **not** do . . . 5
- The outcome . . . 6
- Why it matters to decision-makers . . . 6

Solution Overview — DISA STIG Compliance for Windows 10 & 11 in Microsoft Intune (Government / GCC High edition) 6

- What this solution is . . . 6
- The problem it solves . . . 6
- Commercial vs GCC High / DoD — what's different . . . 7
- How STIG settings are delivered in Intune (unchanged mechanism, sovereign portal) . . . 8
- Named objects you will create (reuse these names throughout) . . . 8
- The standard deployment model . . . 9
- What's inside this package . . . 9
- Who this is for . . . 9

Requirements Guide — Government / GCC High edition 9

- R1. A GCC High or DoD tenant (not Commercial, not GCC) . . . 9
- R2. US Government licensing that carries Intune (Gov SKUs) . . . 10
- R3. Correct sovereign portal access for the operator . . . 10
- R4. Administrative roles (in the Gov tenant) . . . 10
- R5. Windows 10 / 11 devices enrolled in the Gov Intune instance . . . 10
- R6. Network access to US Government endpoints (not Commercial endpoints) . . . 10
- R7. Microsoft Graph PowerShell configured for US Gov . . . 11
- R8. The authoritative DISA STIG benchmark content . . . 11
- R9. (Optional) Advanced Analytics for the STIG audit baseline . . . 11
- R10. Change control / evidence process . . . 11

Global Requirements — Intune Solutions (category-level) 12

- G1. Microsoft Entra ID tenant . . . 12
- G2. Microsoft Intune subscription . . . 12
- G3. Administrative roles . . . 13
- G4. Device enrollment in Intune . . . 13
- G5. Pilot security group . . . 13

G6. Supported Windows baseline . . . 13
G7. Network access to Microsoft cloud endpoints . . . 13
Implementation Guide — Government / GCC High edition 13
Phase 0 — Sign in to the right cloud (do this first) . . . 14
Phase 1 — Assess . . . 14
Phase 2 — Configure (build objects; assign to nobody yet) . . . 14
Phase 3 — Pilot (assign to `SG-STIG-Pilot-Devices` only) . . . 16
Phase 4 — Validate (evidence before you expand) . . . 16
Phase 5 — Expand (roll out under change control) . . . 17
Sovereign-cloud reminders (apply throughout) . . . 17
Testing & Validation — Government / GCC High edition 17
Pre-flight test — you are in the right cloud . . . 17
Gate 1 — Assess . . . 18
Gate 2 — Configure . . . 18
Gate 3 — Pilot . . . 19
Gate 4 — Validate (evidence gate) . . . 19
Gate 5 — Expand . . . 19
Regression & maintenance testing . . . 20
What "done" looks like . . . 20
Troubleshooting — Government / GCC High edition 20
A. Sign-in, portal, and cloud-targeting . . . 20
B. Enrollment & device check-in . . . 21
C. Policy authoring & assignment . . . 21
D. STIG audit baseline (Advanced Analytics) . . . 22
E. Scripts (this package) . . . 22
F. When to escalate to DISA vs Microsoft . . . 23
Quick diagnostic order . . . 23
Best Practices — Government / GCC High edition 23
Sovereign-cloud discipline . . . 23
STIG content governance . . . 24
Object hygiene . . . 24
Safe change management . . . 24
Reliability & operations . . . 24
Documentation & handoff . . . 25
Deliverables Summary — Government / GCC High edition 25
Documents (`source/`) . . . 25

Scripts (`scripts/`) 26
What is deliberately **not** included 27
How the pieces work together 27
Appendix A — PowerShell Scripts 28

Executive Summary — DISA STIG Compliance for Windows 10 & 11 in Microsoft Intune (Government / GCC High edition)

The situation

Government and defense organizations must bring Windows 10 & 11 endpoints into alignment with **DISA Security Technical Implementation Guides (STIGs)** — the DoD's authoritative Windows hardening standard — and increasingly deliver that hardening through **cloud management (Microsoft Intune)** rather than legacy Group Policy. When those tenants run in the **US sovereign cloud (GCC High / IL4 or DoD / IL5)**, the work is materially different from Commercial: the admin portals live on `*.us` domains, automation targets **US Government Microsoft Graph**, and a number of Intune capabilities are **delayed, limited, or absent** versus the Commercial service.

The problem this solves

Following Commercial guidance on a GCC High/DoD tenant fails in two costly ways: sign-ins and scripts hit the wrong cloud, and administrators design around features that **do not exist** in the sovereign environment — discovering the gap only after a failed rollout. Separately, STIGs were written for domain-joined Windows, so each rule must be **translated** into an Intune setting, and mis-scoping a lockdown across an IL4/IL5 fleet is expensive to unwind.

What we deliver

A self-guided, tested implementation package specifically for **GCC High / DoD**:

- **Correct sovereign specifics throughout** — `intune.microsoft.us`, `portal.azure.us`, `portal.office365.us`, US Gov Graph (`graph.microsoft.us` / `dod-graph.microsoft.us`), and PowerShell `-Environment USGov` / `USGovDoD`.
- **A cited Commercial-vs-GCC-High/DoD parity reference** so the deployment routes around missing features (classic Autopilot, Windows Update feature/quality policies, Remote Help, Security Copilot, Cloud PKI) rather than failing on them — every gap pinned to a Microsoft US Gov source and flagged **"verify for GCC High/DoD."**
- **A gated method** — *Assess → Configure → Pilot → Validate → Expand* — with explicit pass/fail criteria that catch breakage in a handful of pilot devices, not thousands.
- **Five US-Gov-Graph-aware PowerShell scripts** — read-only Discovery, Validation, and Reporting for evidence, plus Remediation and Scope-Targeting that default to a safe `-WhatIf` preview.

What we deliberately do not do

We do **not** reproduce or invent DISA STIG rule content. The benchmarks (rule IDs, CCIs, severities, check/fix text) are authored by **DISA** and obtained from the **DoD Cyber Exchange** (`public.cyber.mil`), read in **STIG Viewer**. We supply the **repeatable Intune delivery and validation mechanism** and a method to map DISA's authoritative rules to Intune settings — keeping your program aligned to the real standard, not a copy of it.

The outcome

Windows 10 & 11 STIG alignment **deployed correctly on a GCC High / DoD tenant** — right portals, right endpoints, parity gaps handled, and **evidence captured at every phase gate** — proven on a pilot before it scales, and maintainable as DISA revises the benchmarks.

Why it matters to decision-makers

- **Risk reduction:** avoids the silent-failure and fleet-wide-lockdown mistakes that make sovereign STIG rollouts expensive.
- **Audit readiness:** each phase produces a retained evidence artifact and a benchmark-version → policy-version record — the audit story auditors ask for.
- **Cost:** a self-guided, tested package at a fraction of bespoke consulting, while keeping the authoritative standard where it belongs — with DISA.

Solution Overview — DISA STIG Compliance for Windows 10 & 11 in Microsoft Intune (Government / GCC High edition)

What this solution is

This is the **Government (GCC High / DoD) edition** of the *DISA STIG Compliance for Windows 10 & 11 in Microsoft Intune* solution. It shows a novice administrator how to stand up, pilot, validate, and expand a Windows STIG-alignment program on Microsoft Intune **inside the US sovereign cloud** — the environment used by GCC High (Impact Level 4 / IL4) and Department of Defense (IL5) tenants.

It is **not** the Commercial guide with a different sign-in URL. In the US Government cloud the admin portals live on `*.us` domains, Microsoft Graph uses **US Gov endpoints**, and a number of Intune capabilities are **delayed, limited, or absent** versus Commercial. Following Commercial steps on a GCC High tenant leads to authentication failures and to configuring features that silently do not exist. This edition uses the correct sovereign portals and endpoints throughout and calls out every Commercial-vs-GCC-High parity gap at the step where it matters.

> ***DISA STIG rule content is deferred to the authoritative source.*** *The **Security Technical Implementation Guides (STIGs)** themselves — the rule IDs (`SV-…`), Group IDs (`V-…`), CCIs, severities, and check/fix text — are published and maintained by the **Defense Information Systems Agency (DISA)** at the **DoD Cyber Exchange** ([`https://public.cyber.mil/stigs/`](https://public.cyber.mil/stigs/)) and are read with **STIG Viewer**. This solution does **not** reproduce or invent STIG rule IDs. It teaches you the repeatable Intune **delivery and validation mechanism**; you obtain the current DISA STIG benchmark (e.g., *Microsoft Windows 11 STIG*, *Microsoft Windows 10 STIG*) from DISA and map its rules to Intune settings.*

The problem it solves

STIGs were written for domain-joined, Group Policy-managed Windows. Moving that control set to **cloud-managed (Intune / MDM)** Windows in a **sovereign** tenant introduces three compounding problems:

1. **Translation** — each STIG rule must be expressed as an Intune setting (Settings Catalog, ADMX/Administrative Templates, or a custom OMA-URI), and not every GPO setting has a 1:1 MDM equivalent.

2. **Sovereign portals** — the work happens in `intune.microsoft.us`, not `intune.microsoft.com`; app registrations, scripts, and reporting all target US Gov Graph.

3. **Parity gaps** — some Intune features an admin would reach for in Commercial (for example Windows Autopilot, Remote Help, Windows Update-for-Business feature/quality update policies) are **not available** in GCC High/DoD, so the deployment design must route around them.

This solution supplies a proven, repeatable method plus five PowerShell scripts (all US-Gov-Graph-aware) so a government tenant is configured **correctly on the first pass**, piloted safely, validated with evidence, and expanded under change control.

Commercial vs GCC High / DoD — what's different

The single most important thing to internalize before you touch anything:

Area	Commercial	GCC High / DoD (this edition)
Intune admin center	`https://intune.microsoft.com`	`https://intune.microsoft.us`
Entra / Azure portal	`https://entra.microsoft.com` · `https://portal.azure.com`	`https://portal.azure.us` (Entra blades via the Azure Gov portal)
Microsoft 365 admin	`https://admin.microsoft.com`	`https://portal.office365.us`
Defender portal	`https://security.microsoft.com`	`https://security.microsoft.us`
Purview / compliance	`https://compliance.microsoft.com`	`https://compliance.microsoft.us`
Sign-in authority	`https://login.microsoftonline.com`	`https://login.microsoftonline.us`
Microsoft Graph host	`graph.microsoft.com`	`graph.microsoft.us` (GCC High) · `dod-graph.microsoft.us` (DoD)
Graph PowerShell env	`-Environment Global` (default)	`-Environment USGov` (GCC High) · `-Environment USGovDoD` (DoD)
Device check-in / service	`*.manage.microsoft.com`	`*.manage.microsoft.us`
STIG **audit** baseline (Advanced Analytics)	Rolling out	**GCC High only**, requires Advanced Analytics add-on; **audit-only** (assesses, does not enforce) — *verify current availability for your tenant*
Windows Autopilot (classic)	Available	**Not available** — use Autopilot **device preparation** (partial) or Entra join + Autopilot-independent enrollment
Remote Help	Available	**Planned / not yet available** — *verify for GCC High/DoD*

Area	Commercial	GCC High / DoD (this edition)
Windows Update feature/quality/expedite/driver policies	Available	**Not available** in GCC High/DoD — plan servicing another way
Cloud PKI	Available	**Planned (GCC High only)** — *verify*
Security Copilot in Intune	Available	**Not available**

Sources for the parity table are Microsoft's US Government service description and endpoint docs — see `gcc-high-parity-notes.md` for the full cited list. Because these lists change as Microsoft ships features into the sovereign cloud, every gap in this solution is written as **"verify for GCC High/DoD"** and pinned to a Microsoft US Gov citation rather than asserted as permanent.

How STIG settings are delivered in Intune (unchanged mechanism, sovereign portal)

STIG rules reach Windows devices through the **same three Intune delivery mechanisms** in the sovereign cloud as in Commercial — you just author them in `intune.microsoft.us`:

1. **Settings Catalog** — the primary, modern surface. Most STIG-relevant CSP/ADMX settings are here. In GCC High with **Advanced Analytics** enabled, Microsoft also surfaces a **STIG audit baseline** (audit-only) in Advanced Analytics that assesses devices against DISA STIG recommendations — *verify this is enabled/available for your tenant*.
2. **Administrative Templates (ADMX)** — for classic policy settings expressed as ADMX-backed CSPs.
3. **Custom / OMA-URI profiles** — for STIG rules whose CSP has no catalog UI yet.

Enforcement and audit are complementary: **enforce** the configuration with Settings Catalog/ADMX/custom profiles, and **audit/report** with the STIG audit baseline (where available) plus the reporting script in this package.

Named objects you will create (reuse these names throughout)

To keep the deployment auditable, this solution names its objects once and reuses them. Create them exactly as written:

- **Security group (pilot):** `SG-STIG-Pilot-Devices`
- **Security group (production):** `SG-STIG-Prod-Devices`
- **Settings Catalog profile(s):** `STIG-Win-SettingsCatalog-{domain}` (e.g., `STIG-Win-SettingsCatalog-Account`, `-Audit`, `-Defender`)
- **Administrative Templates profile:** `STIG-Win-ADMX-{domain}` (e.g., `STIG-Win-ADMX-Account`)
- **Custom/OMA-URI profile:** `STIG-Win-Custom-{rule-area}`
- **Compliance policy:** `STIG-Win-Compliance-Baseline`
- **(If used) Advanced Analytics STIG audit baseline instance:** `STIG-Win-AuditBaseline`

The standard deployment model

Every solution in this library follows the same gated model, applied here to the sovereign cloud:

Assess → **Configure** → **Pilot** → **Validate** → **Expand**, with an explicit **gate** between each phase. You do not proceed to the next phase until the current phase's pass criteria are met (see `05-testing.md`). This is doubly important in GCC High/DoD, where mis-scoping a lockdown policy across an IL4/IL5 fleet is operationally expensive to unwind.

What's inside this package

- **Source documents** — this overview, a requirements guide, an implementation guide (sovereign steps + caveats), testing, troubleshooting, best practices, a deliverables summary, an executive summary, and a cited GCC High parity reference.
- **5 PowerShell scripts** — Discovery, Validation, Report (read-only), Remediation and Set-ScopeTargeting (change-making, default `-WhatIf`), all connecting to **US Gov Graph** and supporting `-Environment USGov` and `-Environment USGovDoD`.

Who this is for

Government (GCC High / DoD) administrators and their MSP/consulting partners who must bring Windows 10 & 11 endpoints into alignment with DISA STIGs using Intune, and who need the sovereign-cloud specifics handled correctly rather than discovered through failed sign-ins and missing features.

Requirements Guide — Government / GCC High edition

This guide lists every prerequisite for delivering DISA STIG alignment via Intune **in the US Government cloud (GCC High / DoD)**, and for each one tells you how to **verify** it and how to **implement it if it is missing**.

> *The **category-level global requirements** (Entra tenant, Intune subscription, admin roles, enrollment, pilot group, supported Windows, network access) are published once in `global-requirements-intune-solutions.md` and are **not** repeated in full here. This document covers the **GCC-High/DoD-specific** requirements *and* restates the global ones only where the sovereign cloud changes how you verify or implement them (different portal URLs, licensing SKUs, endpoints).*

Each entry: **Description · Why · Verify · Implement-if-missing.**

R1. A GCC High or DoD tenant (not Commercial, not GCC)

Description: The work must be performed in a **US Government cloud** tenant — GCC High (IL4) or DoD (IL5). **Why:** Intune's government instance is a physically separate, locked-down datacenter shared by GCC High and DoD. Commercial and GCC/GCC-High/DoD are different clouds; there is **no in-place migration** between them (devices must unenroll and re-enroll). Using Commercial steps/URLs against a Gov tenant fails. **Verify:** Sign in at `https://intune.microsoft.us`. If that portal loads and `intune.microsoft.com` does **not** represent your tenant, you are in the Gov cloud. Confirm the sign-in authority is `login.microsoftonline.us`. **Implement:** Acquire the appropriate US Government subscription through an authorized channel (GCC High or DoD). This is a procurement/onboarding action,

not a portal toggle. *Note: "GCC" (state/local) is the Commercial Intune instance — this edition is specifically for **GCC High / DoD**.*

R2. US Government licensing that carries Intune (Gov SKUs)

Description: An Intune-bearing **US Government** license plan for each targeted user/device. **Why:** Only Gov SKUs light up the government Intune instance. **Verify:** `https://portal.office365.us` → **Billing** → **Licenses**; confirm an Intune-bearing Gov plan (e.g., **Microsoft 365 G3/G5 (GCC High or DoD)**, **Enterprise Mobility + Security E3/E5 (Gov)**, or **Intune Plan 1 (Gov)**) is assigned. **Implement:** Purchase/assign the Gov equivalent of the plan you'd use in Commercial. Confirm the exact SKU name with your licensing channel — **verify for GCC High/DoD**, since SKU naming differs from Commercial.

R3. Correct sovereign portal access for the operator

Description: The operator can reach the `*.us` admin portals. **Why:** All configuration happens on sovereign URLs; Commercial URLs won't represent the Gov tenant. **Verify:** Confirm you can load, signed in as an admin: `https://intune.microsoft.us`, `https://portal.azure.us`, `https://portal.office365.us`, and (for validation/reporting) `https://security.microsoft.us`. **Implement:** If a portal is blocked, allow the `*.us` admin hostnames through web filtering (see R6) and confirm the account exists in the Gov tenant.

R4. Administrative roles (in the Gov tenant)

Description: Intune Administrator (and, for role/scope work, appropriate Entra roles) held **in the GCC High/DoD tenant**. **Why:** Creating configuration profiles, compliance policies, and scope tags requires elevated rights; roles are per-tenant. **Verify:** `https://portal.azure.us` → **Microsoft Entra ID** → **Roles and administrators** → confirm **Intune Administrator** on the operator account. **Implement:** Assign **Intune Administrator** in the Gov tenant. Reserve **Global Administrator** for tenant-wide changes only. (This restates global **G3** using the sovereign portal.)

R5. Windows 10 / 11 devices enrolled in the Gov Intune instance

Description: Targeted Windows 10 (21H2+) / Windows 11 devices are Entra-joined and enrolled into the **government** Intune instance. **Why:** Policies only reach enrolled devices, and enrollment must be into the Gov instance (device check-in uses `*.manage.microsoft.us`). **Verify:** `https://intune.microsoft.us` → **Devices** → **All devices**; confirm the pilot devices appear and check in. **Implement:** Enable **automatic enrollment** for Windows in the Gov tenant (`intune.microsoft.us` → **Devices** → **Enrollment**) and Entra-join devices. **Caveat:** classic **Windows Autopilot is not available** in GCC High/DoD — use **Autopilot device preparation** (partial support) or a non-Autopilot enrollment path. **Verify for GCC High/DoD.** (Restates global **G4** with the sovereign caveat.)

R6. Network access to US Government endpoints (not Commercial endpoints)

Description: Outbound HTTPS from devices and admin workstations to the `*.us` service endpoints. **Why:** Enrollment, policy sync, authentication, script/app delivery, and reporting all use sovereign endpoints; SSL inspection is **not supported** on `*.manage.microsoft.us`. **Verify:** From a managed

device, confirm reachability to `login.microsoftonline.us`, `enterpriseregistration.microsoftonline.us`, and `*.manage.microsoft.us`. From the admin workstation, confirm `graph.microsoft.us` (GCC High) or `dod-graph.microsoft.us` (DoD). **Implement:** Allow, through proxy/firewall (and **exclude from SSL inspection** where noted): `*.manage.microsoft.us`, `login.microsoftonline.us`, `enterpriseregistration.microsoftonline.us`, `graph.microsoft.us` / `dod-graph.microsoft.us`, `*.dm.microsoft.us` (Defender/EPM), `*.events.data.microsoft.com`. See `gcc-high-parity-notes.md` for the cited endpoint list. (Restates global **G7** with sovereign hosts.)

R7. Microsoft Graph PowerShell configured for US Gov

Description: The **Microsoft.Graph** PowerShell module installed and able to connect with `-Environment USGov` (GCC High) or `-Environment USGovDoD` (DoD). **Why:** The five scripts in this package, and any Graph automation, must target the sovereign Graph host (`graph.microsoft.us` / `dod-graph.microsoft.us`), not `graph.microsoft.com`. **Verify:** In PowerShell 7+, run `Get-MgEnvironment` and confirm `USGov` and `USGovDoD` are listed; run `Connect-MgGraph -Environment USGov -Scopes "DeviceManagementConfiguration.Read.All"` and confirm `Get-MgContext` shows the Gov account. **Implement:** `Install-Module Microsoft.Graph -Scope CurrentUser`. Use **PowerShell 7+**. If the interactive sign-in popup hangs from a jumpbox, disable the WAM broker: `Set-MgGraphOption -DisableLoginByWAM $true`, then reconnect.

R8. The authoritative DISA STIG benchmark content

Description: The current **DISA STIG** benchmark(s) for your OS — e.g., *Microsoft Windows 11 STIG*, *Microsoft Windows 10 STIG* — plus **STIG Viewer**. **Why:** This solution deliberately does **not** ship STIG rule IDs or check/fix text. You map DISA's authoritative rules to Intune settings; the rules must come from DISA. **Verify:** You have the current benchmark ZIP(s) from the **DoD Cyber Exchange STIGs Document Library** and can open them in **STIG Viewer**. **Implement:** Download from `https://public.cyber.mil/stigs/downloads/` (STIG Viewer from the same site). Track the **benchmark version/release date** — STIGs are revised on a DISA cadence, and your Intune mapping must be re-checked when the benchmark updates.

R9. (Optional) Advanced Analytics for the STIG audit baseline

Description: The Intune **Advanced Analytics** add-on, which surfaces a **STIG audit baseline** in GCC High. **Why:** It provides an audit-only assessment of Windows devices against DISA STIG recommendations (it **assesses**, it does **not enforce**). Enforcement still comes from your Settings Catalog/ADMX/custom profiles. **Verify:** `https://intune.microsoft.us` → **Reports** → **Advanced Analytics** (or Endpoint security → Security baselines) shows the **STIG** audit baseline. Availability is **GCC High only** and requires the add-on. **Verify for GCC High/DoD** — DoD availability and current status can differ. **Implement:** License the **Advanced Analytics** add-on (in addition to Intune Plan 1/Plan 2) via your Gov licensing channel, then enable it in the tenant.

R10. Change control / evidence process

Description: A documented change-control and evidence-capture process appropriate to an IL4/IL5 environment. **Why:** STIG programs are audited; every policy change should be traceable, and every

phase gate should produce evidence (the Report script emits this). **Verify:** You have a place to store `STIGG-Report.ps1` output (JSON/CSV) and a change-approval record for each policy assignment. **Implement:** Define who approves scope-target changes, where evidence is retained, and how the benchmark-version → policy-version mapping is recorded.

Requirements at a glance

#	Requirement	Sovereign specifics
R1	GCC High / DoD tenant	`intune.microsoft.us`; no Commercial↔Gov migration
R2	Gov Intune licensing	G3/G5 Gov, EMS Gov, or Intune P1 Gov — verify SKU
R3	Sovereign portal access	`*.us` admin URLs reachable
R4	Intune Administrator (Gov)	assigned via `portal.azure.us`
R5	Windows enrolled in Gov instance	Autopilot classic N/A — device prep / non-Autopilot
R6	US Gov network endpoints	`*.manage.microsoft.us`, no SSL inspection
R7	Graph PowerShell US Gov	`-Environment USGov` / `USGovDoD`, PS7+
R8	DISA STIG benchmark	from `public.cyber.mil`; track version
R9	Advanced Analytics (optional)	STIG audit baseline, GCC High, audit-only
R10	Change control / evidence	IL4/IL5 audit readiness

Global Requirements — Intune Solutions (category-level)

These requirements apply to **every** solution in the **Intune Solutions** category. They are published once at the category level so individual listings stay small. Confirm these before deploying *any* Intune solution. Each entry: **Description · Why · Verify · Implement-if-missing.**

G1. Microsoft Entra ID tenant

Description: An active Microsoft Entra ID (Azure AD) tenant. **Why:** It is the identity backbone for every cloud and Intune-managed resource. **Verify:** Sign in to `https://entra.microsoft.com` as an administrator. **Implement:** Create a Microsoft 365/Azure subscription, which provisions a tenant.

G2. Microsoft Intune subscription

Description: An Intune-bearing license plan. **Why:** Intune delivers all configuration, compliance, and security policies. **Verify:** `https://intune.microsoft.com` loads; **Tenant administration** → **Tenant**

status shows active. **Implement:** Assign Microsoft 365 E3/E5, Business Premium, or standalone Intune Plan 1.

G3. Administrative roles

Description: Appropriate Entra/Intune admin roles for the operator. **Why:** Creating policies and enrollment settings requires elevated rights. **Verify:** Entra → **Roles and administrators**; confirm **Intune Administrator**. **Implement:** Assign **Intune Administrator**; reserve Global Administrator for tenant-wide changes.

G4. Device enrollment in Intune

Description: Targeted Windows devices are enrolled and manageable. **Why:** Policies only reach enrolled devices. **Verify:** Intune → **Devices** → **All devices**; the device appears and is **compliant**. **Implement:** Enable **Automatic Enrollment** and join devices to Entra ID.

G5. Pilot security group

Description: A Microsoft Entra security group for pilot/targeted users or devices. **Why:** Every solution is piloted before fleet rollout. **Verify:** Entra → **Groups**; the pilot group exists. **Implement:** Entra → **Groups** → **New group** → **Security** → add members.

G6. Supported Windows baseline

Description: Windows 10 21H2+ or Windows 11 with current updates. **Why:** Modern Intune features assume a patched, supported OS. **Verify:** `winver`, or Intune → device → **Hardware**. **Implement:** Deploy **Update rings** or upgrade to Windows 11.

G7. Network access to Microsoft cloud endpoints

Description: Outbound HTTPS to Microsoft 365, Entra, and Intune service URLs. **Why:** Enrollment, policy sync, and authentication depend on these endpoints. **Verify:** From a device, reach `https://login.microsoftonline.com` and `https://enrollment.manage.microsoft.com`. **Implement:** Allow Microsoft's published Office 365/Intune URL & IP ranges through proxy/firewall.

The standard deployment model (all solutions): Assess → Configure → Pilot → Validate → Expand.

Implementation Guide — Government / GCC High edition

This guide walks a **novice administrator** through delivering DISA STIG alignment on Windows 10 & 11 via Intune **in the US Government cloud (GCC High / DoD)**, click-by-click, using the **sovereign** `*.us` **portals**. It follows the gated model **Assess** → **Configure** → **Pilot** → **Validate** → **Expand**. GCC-High/DoD caveats appear inline at the step where they matter.

> ***Before you start:*** *finish* `02-requirements.md`*. You must be signed in to* `https://intune.microsoft.us` *(not* `.com`*) as an* ***Intune Administrator*** *in the Gov tenant, and you must have the* ***DISA STIG benchmark*** *(from* `public.cyber.mil`*) open in* ***STIG Viewer****. This*

*solution supplies the delivery mechanism; the **rule content comes from DISA**.*

Phase 0 — Sign in to the right cloud (do this first)

1. Open a browser and go to `https://intune.microsoft.us`. Sign in; confirm the authority in the address bar is `login.microsoftonline.us`.

2. In a second tab, open `https://portal.azure.us` for Entra ID (Groups, Roles).

3. **Sanity check:** if either portal redirects you to a `.com` sign-in or "tenant not found," you are pointed at Commercial — stop and correct the URL. Everything below assumes `*.us`.

Gate 0: Both `intune.microsoft.us` and `portal.azure.us` load your Gov tenant, and you hold **Intune Administrator**.

Phase 1 — Assess

Goal: know your fleet, your benchmark, and your gaps before changing anything.

1. **Inventory the fleet.** `intune.microsoft.us` → **Devices** → **All devices**. Note Windows 10 vs 11, OS builds, and enrollment state. Confirm devices check in (they use `*.manage.microsoft.us`).

2. **Run Discovery (read-only).** From the admin workstation, run `scripts\STIGG-Discovery.ps1` with `-Environment USGov` (GCC High) or `-Environment USGovDoD` (DoD). It inventories existing configuration profiles, ADMX profiles, compliance policies, security baselines, and target groups so you don't duplicate or collide with existing objects.

3. **Load the DISA benchmark.** Open the current *Microsoft Windows 11 STIG* / *Windows 10 STIG* in **STIG Viewer**. Record the **benchmark version/release date** — you will pin your policy set to it.

4. **Confirm the STIG audit baseline availability (optional, GCC High).** `intune.microsoft.us` → **Reports** → **Advanced Analytics** (or **Endpoint security** → **Security baselines**). If the **STIG** audit baseline appears, note it — it will *assess* (not enforce) devices against DISA recommendations. **If it is absent, that is expected** where Advanced Analytics isn't licensed or where the feature hasn't reached your tenant — **verify for GCC High/DoD**; you will still enforce via Settings Catalog/ADMX/custom.

5. **Map rules → mechanism.** For each STIG rule, decide the Intune delivery mechanism:

- **Settings Catalog** (default, most rules),
- **Administrative Templates (ADMX)** (classic policy settings), or
- **Custom / OMA-URI** (CSP with no catalog UI yet).

Keep this mapping in a spreadsheet keyed by DISA rule ID → Intune setting → chosen profile name.

Gate 1: You have a device inventory, the benchmark version recorded, a rule→mechanism map, and Discovery output showing no naming collisions.

Phase 2 — Configure (build objects; assign to nobody yet)

You will build every object now but **assign to the pilot group only in Phase 3**. Reuse the object names from `01-solution-overview.md`.

2a. Create the target groups

1. `portal.azure.us` → **Microsoft Entra ID** → **Groups** → **New group**.
2. Type **Security**; name `SG-STIG-Pilot-Devices`; add 5–15 representative pilot devices. Create.
3. Repeat to create `SG-STIG-Prod-Devices` (leave empty for now).

(You can also build these with `scripts\STIGG-Set-ScopeTargeting.ps1` — it defaults to `-WhatIf`, so run once to preview, then again with `-WhatIf:$false` to apply.)

2b. Build the Settings Catalog profile(s)

1. `intune.microsoft.us` → **Devices** → **Manage devices** → **Configuration** → **Create** → **New Policy**.
2. **Platform:** Windows 10 and later. **Profile type: Settings catalog**. Create.
3. Name it per convention, e.g., `STIG-Win-SettingsCatalog-Account`. (Split by domain — Account, Audit, Defender, etc. — so a rollback is surgical.)
4. **Add settings** → search for the CSP/ADMX settings your STIG mapping calls for, and set each value to the DISA-specified value. **Do not assign yet** — click through to **Review + create**, leaving assignments empty.
5. Repeat for each domain profile you mapped.

> ***GCC High/DoD parity note:*** *the Settings Catalog surface is the same as Commercial, but individual settings can lag their Commercial debut in the sovereign cloud. If a setting you expect is missing, check whether it's a newer CSP not yet in Gov, and fall back to* ***ADMX*** *or* ***custom OMA-URI*** *for that rule.* ***Verify for GCC High/DoD.***

2c. Build Administrative Templates (ADMX) profile(s) as needed

1. **Configuration** → **Create** → **New Policy** → **Windows 10 and later** → **Templates** → **Administrative Templates**.
2. Name `STIG-Win-ADMX-{domain}`; set the mapped classic policy settings; **Review + create** with no assignments.

2d. Build custom / OMA-URI profile(s) for gaps

1. **Configuration** → **Create** → **New Policy** → **Windows 10 and later** → **Templates** → **Custom**.
2. Name `STIG-Win-Custom-{rule-area}`; add each OMA-URI (name, description, OMA-URI path, data type, value) exactly per the CSP documentation for the rule. **Review + create**, no assignments.

2e. Build the compliance policy

1. **Devices** → **Manage devices** → **Compliance** → **Create policy** → **Windows 10 and later**.
2. Name `STIG-Win-Compliance-Baseline`. Add the rules you want to *gate* device compliance on (e.g., BitLocker, minimum OS build, Defender on). **Review + create**, no assignments yet.

> ***GCC High/DoD parity note:*** *compliance policy and Conditional Access exist in the Gov cloud, but some* ***MTD connectors*** *and integrations available in Commercial may not have a GCC-High-capable*

vendor. When you sign in to a Gov tenant, only the connectors valid there are shown. ***Verify for GCC High/DoD*** *before making a partner integration a compliance dependency.*

2f. (Optional, GCC High) Instantiate the STIG audit baseline

If the **STIG** audit baseline is available (R9): **Endpoint security** → **Security baselines** → **STIG…** → **Create profile**, name it `STIG-Win-AuditBaseline`, accept the audit-only assessment settings, **do not assign yet**. Remember: this **reports**, it does not configure devices.

Gate 2: All objects exist, are named per convention, are pinned to the benchmark version, and have **no assignments**. Re-run `STIGG-Discovery.ps1` to confirm.

Phase 3 — Pilot (assign to `SG-STIG-Pilot-Devices` only)

1. For **each** profile built in Phase 2, open it → **Properties** → **Assignments** → **Edit** → add `SG-STIG-Pilot-Devices` → **Review + save**. Assign the compliance policy and (if used) the audit baseline the same way.

(Or use `scripts\STIGG-Set-ScopeTargeting.ps1` to assign in bulk — preview with the default `-WhatIf`, then apply.)

1. On pilot devices, force a sync: **Settings** → **Accounts** → **Access work or school** → **Info** → **Sync**, or `intune.microsoft.us` → device → **Sync**.

2. Wait for check-in (devices contact `*.manage.microsoft.us`). Confirm each profile shows **Succeeded** for the pilot devices under the profile's **Device status**.

Gate 3: Every pilot assignment shows **Succeeded** (no **Error/Conflict**) on the pilot devices, and pilot users report no functional breakage.

Phase 4 — Validate (evidence before you expand)

1. **Run Validation (read-only):** `scripts\STIGG-Validation.ps1 -Environment USGov` (or `USGovDoD`). It confirms the pilot assignments match the intended object set and flags conflicts, unassigned profiles, and drift.

2. **Run Report (read-only):** `scripts\STIGG-Report.ps1 -Environment USGov` to produce a JSON/CSV evidence artifact of profile/compliance/baseline state for the pilot group. Store it per your change-control process (R10).

3. **Check the audit baseline (if used):** review the STIG audit results in Advanced Analytics for the pilot devices; note assessed-vs-target deltas. Remember these are **advisory** — enforcement is your profiles.

4. **Functional check:** verify pilot devices still perform their mission workload (sign-in, LOB apps, VPN/Tunnel, printing). STIG lockdowns can break workflows; catch it in pilot, not production.

Gate 4: Validation clean, Report evidence captured, audit deltas understood/accepted, no functional regressions. **Only now proceed to Expand.**

Phase 5 — Expand (roll out under change control)

1. Add production devices to `SG-STIG-Prod-Devices` in waves (e.g., 10% → 25% → 50% → 100%). Use `STIGG-Set-ScopeTargeting.ps1` (default `-WhatIf` first) to add the prod group to each profile's assignments, or add it in the portal.

2. After **each wave**, re-run `STIGG-Validation.ps1` and `STIGG-Report.ps1`; hold the wave if errors/conflicts appear.

3. **Remediate drift** with `scripts\STIGG-Remediation.ps1` — it defaults to `-WhatIf`; review the planned actions, then re-run with `-WhatIf:$false` to apply only the changes you approved.

4. **Maintain against benchmark updates:** when DISA releases a new STIG benchmark version, re-open it in STIG Viewer, update your rule→setting map, revise the affected profiles, bump their benchmark-version pin, and re-pilot the delta before expanding.

Gate 5: 100% of `SG-STIG-Prod-Devices` reporting **Succeeded**, evidence captured per wave, and a documented benchmark-version → policy-version record.

Sovereign-cloud reminders (apply throughout)

• Always operate in `intune.microsoft.us` / `portal.azure.us`; scripts always use `-Environment USGov` or `-Environment USGovDoD`.

• **Do not** rely on Commercial-only features (classic Autopilot, Windows Update feature/quality/expedite/driver policies, Remote Help, Security Copilot, Cloud PKI) — see `gcc-high-parity-notes.md` and design around the gaps. **Verify current availability for GCC High/DoD** before assuming a feature is present.

• **SSL inspection is not supported** on `*.manage.microsoft.us` — exclude it, or enrollment/check-in fails.

• STIG **rule content stays with DISA**; you deliver and validate it with Intune.

Testing & Validation — Government / GCC High edition

Testing in this solution is **gate-based**: each phase of *Assess → Configure → Pilot → Validate → Expand* has explicit **pass/fail** criteria, and you do not advance until the gate passes. All validation runs against the **US Government cloud** — the read-only scripts connect with `-Environment USGov` (GCC High) or `-Environment USGovDoD` (DoD).

> *The read-only trio — `STIGG-Discovery.ps1`, `STIGG-Validation.ps1`, `STIGG-Report.ps1` — make **no changes**. Run them freely. `STIGG-Remediation.ps1` and `STIGG-Set-ScopeTargeting.ps1` default to `-WhatIf` and only change state when you re-run with `-WhatIf:$false`.*

Pre-flight test — you are in the right cloud

Check	How	Pass
Sovereign portal	Load `https://intune.microsoft.us`	Loads your Gov tenant; authority is `login.microsoftonline.us`
Graph environment	`Get-MgEnvironment`	`USGov` **and** `USGovDoD` listed
Graph connect	`Connect-MgGraph -Environment USGov -Scopes "DeviceManagementConfiguration.Read.All"` then `Get-MgContext`	Shows Gov account; **no** `graph.microsoft.com` in play
Endpoints	From a device, reach `*.manage.microsoft.us`, `login.microsoftonline.us`	Reachable; **not** SSL-inspected

Fail action: if any check points at `.com`, stop — you are configured for Commercial. Correct URLs/endpoints and the `-Environment` value before testing anything else.

Gate 1 — Assess

Test	Pass criteria
Fleet inventory captured	Windows 10/11 counts, builds, enrollment state recorded
`STIGG-Discovery.ps1` run	Output lists existing profiles/policies/baselines/groups; **no naming collisions** with this solution's objects
Benchmark loaded	Current DISA STIG benchmark open in STIG Viewer; **version/release date recorded**
Rule→mechanism map	Each in-scope STIG rule assigned to Settings Catalog / ADMX / Custom

Fail: missing inventory, a name collision, or an unrecorded benchmark version → resolve before Configure.

Gate 2 — Configure

Test	Pass criteria
Objects exist	All profiles (`STIG-Win-SettingsCatalog-*`, `STIG-Win-ADMX-*`, `STIG-Win-Custom-*`), `STIG-Win-Compliance-Baseline`, and (if used) `STIG-Win-AuditBaseline` created
Naming convention	Every object matches the names in `01-solution-overview.md`
No assignments	Every object is assigned to **nobody**

Test	Pass criteria
Benchmark pin	Each profile's description records the benchmark version it implements
Re-Discovery	Second `STIGG-Discovery.ps1` run confirms objects present, unassigned

Fail: any object assigned early, or off-convention naming → fix before Pilot (an early assignment is a change you didn't gate).

Gate 3 — Pilot

Test	Pass criteria
Pilot scope only	Every profile/policy assigned to `SG-STIG-Pilot-Devices` and nothing else
Deployment status	Each profile's **Device status** shows **Succeeded** on pilot devices
No conflicts	**Zero Error** / **Conflict** states
Functional	Pilot users report no broken sign-in, LOB app, VPN/Tunnel, or print workflow

Fail action: a **Conflict** means two policies set the same setting differently — see `06-troubleshooting.md`. An **Error** on a custom OMA-URI usually means a malformed path/value or a CSP not present in the Gov cloud (**verify for GCC High/DoD**).

Gate 4 — Validate (evidence gate)

Test	Pass criteria
`STIGG-Validation.ps1 -Environment USGov`	Reports pilot assignments == intended set; **no** drift/conflict/unassigned flags
`STIGG-Report.ps1 -Environment USGov`	Produces JSON/CSV evidence; stored per change-control (R10)
Audit baseline review (if used)	Advanced Analytics STIG assessment reviewed; assessed-vs-target deltas understood (advisory only)
Regression	Pilot devices complete mission workload unchanged

Fail: any validation flag or unexplained audit delta → remediate in pilot and re-run. **Do not expand on a failed Gate 4.**

Gate 5 — Expand

Test (per wave)	Pass criteria
Wave scope	Correct devices in `SG-STIG-Prod-Devices` for this wave
Post-wave validation	`STIGG-Validation.ps1` clean after each wave
Post-wave evidence	`STIGG-Report.ps1` artifact captured per wave
Remediation (if run)	`STIGG-Remediation.ps1` previewed with `-WhatIf`, applied only for approved deltas
Final	100% of prod group **Succeeded**; benchmark→policy version record complete

Fail: errors in a wave → **hold**, remediate, re-validate before the next wave.

Regression & maintenance testing

- **On every DISA benchmark update:** re-run Discovery/Validation after revising profiles; re-pilot the changed rules (mini Gate 3 → Gate 4) before pushing to prod.
- **Monthly drift check:** run `STIGG-Report.ps1` against prod and compare to the last stored artifact; investigate any newly non-compliant devices.
- **After tenant/feature changes:** if Microsoft ships a previously-missing feature into GCC High/DoD (e.g., a new Settings Catalog CSP), re-check whether a custom OMA-URI workaround can be retired.

What "done" looks like

All five gates passed, prod fleet reporting **Succeeded**, an evidence artifact per wave retained, a recorded mapping of **DISA benchmark version** → **deployed policy version**, and every step performed in the **sovereign** `*.us` cloud with `-Environment USGov`/`USGovDoD`.

Troubleshooting — Government / GCC High edition

Symptom-first fixes for the most common failures when delivering DISA STIG alignment via Intune in the **US Government cloud (GCC High / DoD)**. Most GCC-High-specific failures trace back to one of three roots: **wrong cloud/URL**, **SSL-inspected** `*.us` **endpoints**, or **assuming a Commercial-only feature exists**.

A. Sign-in, portal, and cloud-targeting

Symptom: the admin portal shows "tenant not found," redirects to a `.com` **sign-in, or shows a different tenant.**

- **Cause:** you opened the **Commercial** portal.
- **Fix:** use `https://intune.microsoft.us` and `https://portal.azure.us`. Confirm the sign-in authority is `login.microsoftonline.us`. Clear cached `.com` sessions if the browser auto-redirects.

Symptom: `Connect-MgGraph` **succeeds but scripts see none of your Intune objects.**

- **Cause:** you connected to the **Global** (Commercial) cloud — the default.
- **Fix:** always pass `-Environment USGov` (GCC High) or `-Environment USGovDoD` (DoD). Verify with `Get-MgContext`; the account/host must be the sovereign one (`graph.microsoft.us` / `dod-graph.microsoft.us`). Run `Get-MgEnvironment` to confirm both Gov environments are present.

Symptom: the interactive Graph sign-in popup hangs or times out (often from a jumpbox).

- **Cause:** the WAM broker doesn't work in that environment.
- **Fix:** `Set-MgGraphOption -DisableLoginByWAM $true` (persists across sessions), then reconnect. Use **PowerShell 7+**.

Symptom: `-Environment USGovDoD` **fails but** `USGov` **works (or vice-versa).**

- **Cause:** you're using the wrong Gov sub-cloud for your tenant. GCC High = `USGov`; DoD = `USGovDoD` (`dod-graph.microsoft.us`).
- **Fix:** match `-Environment` to your tenant type.

B. Enrollment & device check-in

Symptom: devices won't enroll, or enrolled devices never check in / never receive policy.

- **Cause 1 — SSL inspection on** `*.manage.microsoft.us`**.** This is **unsupported** and silently breaks check-in.
- **Fix:** exclude `*.manage.microsoft.us` (and `*.dm.microsoft.us` for Defender/EPM) from SSL/TLS inspection.
- **Cause 2 — Commercial endpoints allowed instead of** `*.us`**.**
- **Fix:** allow the **US Gov** endpoints (`*.manage.microsoft.us`, `login.microsoftonline.us`, `enterpriseregistration.microsoftonline.us`, `graph.microsoft.us`/`dod-graph.microsoft.us`, `*.events.data.microsoft.com`). See `gcc-high-parity-notes.md` §3.
- **Cause 3 — proxy requires auth for update downloads.**
- **Fix:** some tasks need **unauthenticated** proxy access to `manage.microsoft.us`.

Symptom: "I set up Autopilot but it doesn't work in GCC High."

- **Cause:** classic **Windows Autopilot is not available** in GCC High/DoD.
- **Fix:** use **Autopilot device preparation** (partial — user-driven only) or a non-Autopilot enrollment (Entra join + automatic enrollment). See parity notes §6–§7.

C. Policy authoring & assignment

Symptom: a Settings Catalog setting I need in Commercial isn't in `intune.microsoft.us`**.**

- **Cause:** the CSP hasn't reached the sovereign cloud yet (features lag in GCC High/DoD).

• **Fix:** first confirm it isn't a permanent gap (parity notes §6–§7). If it's just lagging, deliver that STIG rule via **Administrative Templates (ADMX)** or a **custom OMA-URI** profile (`03-implementation.md` §2c–2d). **Verify for GCC High/DoD.**

Symptom: profile deployment shows Conflict on a device.

• **Cause:** two profiles set the **same setting** to different values.

• **Fix:** run `STIGG-Validation.ps1 -Environment USGov`; it flags overlapping settings. Consolidate to one authoritative profile per domain (best-practice: split by domain, one owner per setting).

Symptom: a custom OMA-URI profile shows Error.

• **Cause:** malformed OMA-URI path/data type/value, or the CSP doesn't exist in the Gov cloud.

• **Fix:** re-check the OMA-URI against the CSP reference; confirm the CSP is available in GCC High/DoD (**verify**). Test on one pilot device before wider assignment.

Symptom: I assigned a lockdown and broke a workflow across many devices.

• **Cause:** assignment skipped the pilot gate, or expanded before Gate 4.

• **Fix:** remove the prod assignment, re-scope to `SG-STIG-Pilot-Devices`, and re-run the gates. This is exactly what the gated model prevents — never assign a new lockdown fleet-wide at once.

D. STIG audit baseline (Advanced Analytics)

Symptom: the STIG audit baseline doesn't appear.

• **Cause:** Advanced Analytics isn't licensed/enabled, or the feature hasn't reached your tenant (it's GCC-High-oriented).

• **Fix:** confirm the **Advanced Analytics** add-on is licensed and enabled (`02-requirements.md` R9). **Verify for GCC High/DoD** — DoD status can differ. If unavailable, that's expected; enforce via profiles and report with `STIGG-Report.ps1`.

Symptom: audit baseline shows non-compliance but my enforcement profiles are applied.

• **Cause:** the audit baseline is **audit-only** and assesses against DISA recommendations that may exceed what you enforce, or the device hasn't re-checked-in.

• **Fix:** treat audit results as **advisory**. Reconcile deltas against your rule→setting map; force a device sync; decide whether to add the flagged setting to an enforcement profile.

E. Scripts (this package)

Symptom: a script errors on connect.

• **Fix:** ensure `Install-Module Microsoft.Graph` is done, you're on **PS7+**, and you pass `-Environment USGov`/`USGovDoD`. Confirm required read scopes were consented.

Symptom: `STIGG-Remediation.ps1` **/** `STIGG-Set-ScopeTargeting.ps1` **"didn't do anything."**

• **Cause:** they default to `-WhatIf` (preview only) — by design.

• **Fix:** review the previewed actions, get approval, then re-run with `-WhatIf:$false` to apply.

Symptom: Report/Validation output looks empty.

• **Cause:** connected to the wrong cloud, or insufficient read scope.

• **Fix:** verify `Get-MgContext` shows the Gov host; re-consent read scopes (`DeviceManagementConfiguration.Read.All`, `DeviceManagementManagedDevices.Read.All`).

F. When to escalate to DISA vs Microsoft

• **Rule content questions** (what a STIG rule requires, its severity/CCI) → **DISA / DoD Cyber Exchange** (`public.cyber.mil`) and **STIG Viewer**. This solution does not author rule content.

• **Intune/sovereign platform questions** (a setting missing in Gov, an endpoint behavior, feature availability) → **Microsoft US Gov support** and the cited Microsoft Learn docs in `gcc-high-parity-notes.md`.

Quick diagnostic order

1. Am I in `*.us` and on `-Environment USGov/USGovDoD`? (Root of most issues.)
2. Are the `*.us` **endpoints** allowed and **not SSL-inspected**?
3. Is the feature I expect **actually available** in GCC High/DoD? (Parity notes §6–§7.)
4. Did I skip a **gate** (assigned before pilot/validate)?
5. For scripts: PS7+, module installed, correct `-Environment`, `-WhatIf` understood.

Best Practices — Government / GCC High edition

Operating principles for running a DISA STIG-alignment program on Intune in the **US Government cloud (GCC High / DoD)**. These assume you have implemented the solution per `03-implementation.md` and are now sustaining it.

Sovereign-cloud discipline

• **Bookmark the `*.us` portals and delete the `.com` ones.** `intune.microsoft.us`, `portal.azure.us`, `portal.office365.us`, `security.microsoft.us`. The most common GCC High mistake is doing real work in the Commercial portal by muscle memory.

• **Pin `-Environment` in every script and runbook.** Never run Graph automation without an explicit `-Environment USGov` (GCC High) or `-Environment USGovDoD` (DoD). A default (`Global`) connection silently talks to the wrong cloud.

• **Never SSL-inspect `*.manage.microsoft.us`.** It is unsupported and breaks enrollment/check-in. Exclude it (and the Defender/EPM `*.dm.microsoft.us` hosts) from inspection.

• **Assume parity gaps until proven otherwise.** Before designing around any Intune feature, confirm it exists in GCC High/DoD today (see `gcc-high-parity-notes.md`). Treat every gap as **"verify for**

GCC High/DoD" — the sovereign feature set moves.

STIG content governance

• **DISA owns the rules; you own the delivery.** Always pull benchmarks from `public.cyber.mil` and read them in **STIG Viewer**. Do not hand-copy rule IDs or invent settings — map DISA's authoritative rules to Intune.

• **Version-pin everything.** Record the DISA **benchmark version/release date** in each profile's description, and keep a **benchmark-version** → **deployed-policy-version** ledger. Auditors ask "which STIG release is this fleet on?"

• **Track the DISA revision cadence.** When a new benchmark drops, treat it as a change: update the map, revise profiles, re-pilot the delta, then expand.

• **Separate enforce from audit.** Enforce with Settings Catalog/ADMX/custom profiles; use the **STIG audit baseline** (Advanced Analytics, GCC High, if licensed) as an **advisory assessment**, not as the control itself.

Object hygiene

• **One naming convention, reused everywhere.** Use the names from `01-solution-overview.md` (`SG-STIG-Pilot-Devices`, `STIG-Win-SettingsCatalog-{domain}`, `STIG-Win-Compliance-Baseline`, …). Consistent names make rollback and audit surgical.

• **Split profiles by domain, not one mega-profile.** Account, Audit, Defender, etc. A conflict or rollback then touches one domain, not the whole STIG.

• **Group-based targeting, device groups for STIG.** Target device groups (`SG-STIG-*-Devices`) so posture follows the machine regardless of user.

• **Keep** `SG-STIG-Prod-Devices` **wave-managed.** Add in waves (10/25/50/100%); never assign a new lockdown to the whole fleet at once.

Safe change management

• `-WhatIf` **first, always.** `STIGG-Remediation.ps1` and `STIGG-Set-ScopeTargeting.ps1` default to `-WhatIf`. Read the preview, get approval, then apply with `-WhatIf:$false`.

• **Evidence every phase.** Run `STIGG-Report.ps1` at Validate and after each Expand wave; retain the JSON/CSV per your IL4/IL5 change-control process.

• **Least privilege for operators.** Assign **Intune Administrator** in the Gov tenant; reserve **Global Administrator** for tenant-wide changes. Consider **scope tags** to fence STIG objects from other admins.

• **Pilot is not optional.** In an IL4/IL5 fleet, an over-broad lockdown is expensive to unwind. The gates exist to catch breakage in 5–15 pilot devices, not thousands.

Reliability & operations

• **Design around missing servicing features.** GCC High/DoD lacks Intune Windows Update **feature/quality/expedite/driver** policies — plan patching via your available servicing path and **verify**

for GCC High/DoD as Microsoft ships these.

• **Confirm connector availability before depending on it.** Only MTD/partner connectors valid in the Gov cloud appear when you sign in; don't make a Commercial-only integration a compliance dependency.

• **PowerShell 7+ on the admin workstation.** The Graph SDK's sovereign-cloud auth (and WAM workaround `Set-MgGraphOption -DisableLoginByWAM $true` from jumpboxes) is most reliable on PS7+.

• **Re-run Discovery before big changes.** A quick `STIGG-Discovery.ps1` catches drift and object collisions before you touch assignments.

Documentation & handoff

• Keep the **rule→setting map**, the **benchmark-version ledger**, and the **per-wave evidence** together. That package *is* your STIG program's audit story.

• Note any rule delivered via **custom OMA-URI because the CSP wasn't yet in GCC High** — revisit those when the sovereign feature set catches up, and retire the workaround.

Deliverables Summary — Government / GCC High edition

Everything included in the **Government (GCC High / DoD)** edition of *DISA STIG Compliance for Windows 10 & 11 in Microsoft Intune*, and what each piece is for.

Documents (`source/`)

Document	Purpose
01-solution-overview.md	What the solution is, the problem it solves, and a **Commercial vs GCC High / DoD — what's different** table (portals, Graph, parity). Names the reusable objects and the deployment model.
02-requirements.md	Every prerequisite with **verify** + **implement-if-missing**, GCC-High/DoD-specific (Gov tenant, Gov licensing, sovereign portal access, Gov endpoints, Graph US Gov, DISA benchmark, Advanced Analytics). Restates global requirements only where the sovereign cloud changes them.
03-implementation.md	Click-by-click ordered steps in the `*.us` portals, gated **Assess** → **Configure** → **Pilot** → **Validate** → **Expand**, with GCC-High/DoD caveats inline.
05-testing.md	Pass/fail **gate** criteria for each phase, plus a pre-flight "am I in the right cloud" test and maintenance/regression testing.

Document	Purpose
06-troubleshooting.md	Symptom-first fixes, rooted in the three common GCC High failure modes (wrong cloud/URL, SSL-inspected `*.us` endpoints, assuming Commercial-only features).
07-best-practices.md	Operating principles: sovereign-cloud discipline, STIG content governance, object hygiene, safe change management.
gcc-high-parity-notes.md	**Cited** Commercial-vs-GCC-High/DoD reference — portals, Graph environments, endpoints, supported/planned/unavailable features, and the STIG audit baseline — each pinned to a Microsoft US Gov source, all flagged **"verify for GCC High/DoD."**
executive-summary.md	One-page, decision-maker framing of value, risk, and outcome.
08-deliverables-summary.md	This inventory.
global-requirements-intune-solutions.md	Category-level prerequisites (provided; not authored here).

Scripts (`scripts/`)

All five connect to **US Gov Microsoft Graph** and support `-Environment USGov` (GCC High) and `-Environment USGovDoD` (DoD). The read-only three make **no changes**; the two change-making scripts default to `-WhatIf`.

Script	Type	Purpose
STIGG-Discovery.ps1	Read-only	Inventories existing configuration/ADMX/custom profiles, compliance policies, security baselines, and target groups so you don't collide or duplicate before configuring.
STIGG-Validation.ps1	Read-only	Confirms assignments match the intended object set; flags conflicts, drift, and unassigned profiles at each gate.
STIGG-Report.ps1	Read-only	Emits a JSON/CSV **evidence** artifact of profile/compliance/baseline state for a target group — the audit record for Validate and each Expand wave.

Script	Type	Purpose
STIGG-Remediation.ps1	**Change (default `-WhatIf`)**	Previews then (with `-WhatIf:$false`) applies approved fixes for drifted/misassigned objects.
STIGG-Set-ScopeTargeting.ps1	**Change (default `-WhatIf`)**	Previews then applies group creation and profile/policy **assignment** (pilot → prod waves) in bulk.

What is deliberately not included

• **DISA STIG rule content** — rule IDs, CCIs, severities, check/fix text. These are authored by **DISA** and obtained from the **DoD Cyber Exchange** (`public.cyber.mil`) and read in **STIG Viewer**. This solution supplies the **Intune delivery and validation mechanism**, and a rule→setting mapping method — not the rules themselves.

• **Tenant secrets** — no tokens, keys, or credentials are shipped or required to be embedded; scripts authenticate interactively to US Gov Graph.

How the pieces work together

1. **Read** `01`/`02`, satisfy requirements, sign in to `intune.microsoft.us`.
2. **Assess** with `STIGG-Discovery.ps1` and the DISA benchmark (STIG Viewer).
3. **Configure** objects per `03` (Settings Catalog / ADMX / custom + compliance + optional audit baseline).
4. **Pilot** → **Validate** with `STIGG-Validation.ps1` + `STIGG-Report.ps1` against `SG-STIG-Pilot-Devices`, passing each **gate** in `05`.
5. **Expand** in waves with `STIGG-Set-ScopeTargeting.ps1` and `STIGG-Remediation.ps1` (both `-WhatIf` first), re-validating per wave.
6. **Sustain** per `07` and re-pilot on each DISA benchmark update.

Every step runs in the **sovereign** `*.us` cloud with `-Environment USGov`/`USGovDoD`, with parity gaps handled per `gcc-high-parity-notes.md`.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

STIGG-Discovery.ps1

Purpose: Inventories existing configuration profiles, Administrative Template (ADMX) profiles, custom (OMA-URI) profiles, compliance policies, security baselines, and Entra device groups so you do not collide with or duplicate objects before configuring. Read-only: it changes nothing. Connects to Microsoft Graph US Gov endpoints. Replace placeholders like your-tenant-id inline. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\STIGG-Discovery.ps1 powershell -ExecutionPolicy Bypass -File .\STIGG-Discovery.ps1 -Environment USGovDoD (Graph scopes: DeviceManagementConfiguration.Read.All, DeviceManagementManagedDevices.Read.All, Group.Read.All; -Environment USGov for GCC High or USGovDoD for DoD) EXPECTED RESULTS A console summary and an optional JSON export listing each object by name and id. Admin sees counts per object type and any names that match this solution's naming convention (STIG-Win-*, SG-STIG-*). PASS = inventory returns without error and no naming collisions with objects you intend to create. FAIL = connect error (wrong cloud/scopes) or an unexpected pre-existing STIG-Win-* object. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

How to run: powershell -ExecutionPolicy Bypass -File .\STIGG-Discovery.ps1 powershell -ExecutionPolicy Bypass -File .\STIGG-Discovery.ps1 -Environment USGovDoD (Graph scopes: DeviceManagementConfiguration.Read.All, DeviceManagementManagedDevices.Read.All, Group.Read.All; -Environment USGov for GCC High or USGovDoD for DoD) EXPECTED RESULTS A console summary and an optional JSON export listing each object by name and id. Admin sees counts per object type and any names that match this solution's naming convention (STIG-Win-*, SG-STIG-*). PASS = inventory returns without error and no naming collisions with objects you intend to create. FAIL = connect error (wrong cloud/scopes) or an unexpected pre-existing STIG-Win-* object. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

STIGG-Remediation.ps1

Purpose: Applies approved remediation to this solution's STIG objects: re-adds a missing target-group assignment and (optionally) removes an unintended group assignment so a profile matches the phase's intended scope. Defaults to -WhatIf, so it only PREVIEWS actions; nothing changes until you re-run with -WhatIf:$false. It does not author or change STIG rule content — that stays with DISA. HOW TO RUN Preview (safe): powershell -ExecutionPolicy Bypass -File .\STIGG-Remediation.ps1 -TargetGroup SG-STIG-Pilot-Devices Apply: powershell -ExecutionPolicy Bypass -File .\STIGG-Remediation.ps1 -TargetGroup SG-STIG-Pilot-Devices -WhatIf:$false DoD tenant: add -Environment USGovDoD (Graph scopes: DeviceManagementConfiguration.ReadWrite.All, Group.Read.All; -Environment USGov for GCC High or USGovDoD for DoD) EXPECTED RESULTS A list of planned assignment changes. In preview (default) admin sees "WHATIF: would ..." lines and nothing is modified. With -WhatIf:$false, approved assignments are added/removed and confirmed. PASS = each intended object ends assigned to TargetGroup. Re-run STIGG-Validation.ps1 to confirm. .NOTES White-label — the repeatable way. Change-making; defaults to -WhatIf. Targets Microsoft Graph US Gov endpoints. #>

How to run: Preview (safe): powershell -ExecutionPolicy Bypass -File .\STIGG-Remediation.ps1 -TargetGroup SG-STIG-Pilot-Devices Apply: powershell -ExecutionPolicy Bypass -File .\STIGG-Remediation.ps1 -TargetGroup SG-STIG-Pilot-Devices -WhatIf:$false DoD tenant: add

-Environment USGovDoD (Graph scopes: DeviceManagementConfiguration.ReadWrite.All, Group.Read.All; -Environment USGov for GCC High or USGovDoD for DoD) EXPECTED RESULTS A list of planned assignment changes. In preview (default) admin sees "WHATIF: would ..." lines and nothing is modified. With -WhatIf:$false, approved assignments are added/removed and confirmed. PASS = each intended object ends assigned to TargetGroup. Re-run STIGG-Validation.ps1 to confirm. .NOTES White-label — the repeatable way. Change-making; defaults to -WhatIf. Targets Microsoft Graph US Gov endpoints. #>

STIGG-Report.ps1

Purpose: Produces an evidence artifact (JSON and CSV) capturing the deployment state of this solution's STIG objects and the compliance posture of devices in a target group. Run at the Validate gate and after each Expand wave, then retain the output per your IL4/IL5 change-control process. Read-only: it changes nothing. Do not embed secrets; authenticate interactively to US Gov Graph. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\STIGG-Report.ps1 -TargetGroup SG-STIG-Pilot-Devices powershell -ExecutionPolicy Bypass -File .\STIGG-Report.ps1 -TargetGroup SG-STIG-Prod-Devices -Environment USGovDoD -OutputDir .\evidence (Graph scopes: DeviceManagementConfiguration.Read.All, DeviceManagementManagedDevices.Read.All, Group.Read.All; -Environment USGov for GCC High or USGovDoD for DoD) EXPECTED RESULTS Two files (STIGG-Report-timestamp.json and .csv) plus a console summary. Admin sees object deployment states and per-device compliance counts. PASS = report generates and reflects the expected assigned objects and compliant devices. Used as the retained audit record, not a gate by itself. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

How to run: powershell -ExecutionPolicy Bypass -File .\STIGG-Report.ps1 -TargetGroup SG-STIG-Pilot-Devices powershell -ExecutionPolicy Bypass -File .\STIGG-Report.ps1 -TargetGroup SG-STIG-Prod-Devices -Environment USGovDoD -OutputDir .\evidence (Graph scopes: DeviceManagementConfiguration.Read.All, DeviceManagementManagedDevices.Read.All, Group.Read.All; -Environment USGov for GCC High or USGovDoD for DoD) EXPECTED RESULTS Two files (STIGG-Report-timestamp.json and .csv) plus a console summary. Admin sees object deployment states and per-device compliance counts. PASS = report generates and reflects the expected assigned objects and compliant devices. Used as the retained audit record, not a gate by itself. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

STIGG-Set-ScopeTargeting.ps1

Purpose: Creates this solution's Entra device security groups (SG-STIG-Pilot-Devices, SG-STIG-Prod-Devices) if missing, and bulk-assigns the STIG-Win-* profiles/policies to a chosen target group for the current phase (pilot, then prod expansion waves). Defaults to -WhatIf, so it only PREVIEWS actions; nothing changes until you re-run with -WhatIf:$false. HOW TO RUN Preview (safe): powershell -ExecutionPolicy Bypass -File .\STIGG-Set-ScopeTargeting.ps1 -TargetGroup SG-STIG-Pilot-Devices -CreateGroups Apply: powershell -ExecutionPolicy Bypass -File .\STIGG-Set-ScopeTargeting.ps1 -TargetGroup SG-STIG-Pilot-Devices -CreateGroups -WhatIf:$false DoD tenant: add -Environment USGovDoD (Graph scopes: DeviceManagementConfiguration.ReadWrite.All, Group.ReadWrite.All; -Environment USGov for GCC High or USGovDoD for DoD) EXPECTED RESULTS A list of planned group creations and profile assignments. In preview (default) admin sees "WHATIF: would ..." lines and nothing is modified. With -WhatIf:$false, groups are created and STIG-Win-* objects are assigned to TargetGroup. PASS = groups exist and objects are assigned. Confirm with STIGG-Validation.ps1. .NOTES White-label — the repeatable way. Change-making; defaults to -WhatIf. Targets Microsoft Graph US Gov endpoints.

#>

How to run: Preview (safe): powershell -ExecutionPolicy Bypass -File .\STIGG-Set-ScopeTargeting.ps1 -TargetGroup SG-STIG-Pilot-Devices -CreateGroups Apply: powershell -ExecutionPolicy Bypass -File .\STIGG-Set-ScopeTargeting.ps1 -TargetGroup SG-STIG-Pilot-Devices -CreateGroups -WhatIf:$false DoD tenant: add -Environment USGovDoD (Graph scopes: DeviceManagementConfiguration.ReadWrite.All, Group.ReadWrite.All; -Environment USGov for GCC High or USGovDoD for DoD) EXPECTED RESULTS A list of planned group creations and profile assignments. In preview (default) admin sees "WHATIF: would ..." lines and nothing is modified. With -WhatIf:$false, groups are created and STIG-Win-* objects are assigned to TargetGroup. PASS = groups exist and objects are assigned. Confirm with STIGG-Validation.ps1. .NOTES White-label — the repeatable way. Change-making; defaults to -WhatIf. Targets Microsoft Graph US Gov endpoints. #>

STIGG-Validation.ps1

Purpose: Validates that this solution's STIG objects (STIG-Win-* profiles/policies and SG-STIG-* groups) exist, are assigned only to the intended target group for the current phase, and are free of setting conflicts and orphaned (unassigned) profiles. Used as the pass/fail gate check at Pilot, Validate, and each Expand wave. Read-only: it changes nothing. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\STIGG-Validation.ps1 -TargetGroup SG-STIG-Pilot-Devices powershell -ExecutionPolicy Bypass -File .\STIGG-Validation.ps1 -TargetGroup SG-STIG-Prod-Devices -Environment USGovDoD (Graph scopes: DeviceManagementConfiguration.Read.All, DeviceManagementManagedDevices.Read.All, Group.Read.All; -Environment USGov for GCC High or USGovDoD for DoD) EXPECTED RESULTS A per-object PASS/FAIL table. Admin sees which STIG-Win-* objects are assigned to the expected group, any conflicts, and any unassigned profiles. Overall PASS = all intended objects assigned to TargetGroup, no conflicts, no orphans. FAIL = missing assignment, wrong-group assignment, conflict, or orphan — resolve before advancing the gate. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

How to run: powershell -ExecutionPolicy Bypass -File .\STIGG-Validation.ps1 -TargetGroup SG-STIG-Pilot-Devices powershell -ExecutionPolicy Bypass -File .\STIGG-Validation.ps1 -TargetGroup SG-STIG-Prod-Devices -Environment USGovDoD (Graph scopes: DeviceManagementConfiguration.Read.All, DeviceManagementManagedDevices.Read.All, Group.Read.All; -Environment USGov for GCC High or USGovDoD for DoD) EXPECTED RESULTS A per-object PASS/FAIL table. Admin sees which STIG-Win-* objects are assigned to the expected group, any conflicts, and any unassigned profiles. Overall PASS = all intended objects assigned to TargetGroup, no conflicts, no orphans. FAIL = missing assignment, wrong-group assignment, conflict, or orphan — resolve before advancing the gate. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>